

PHISHING DETECTION & AWARENESS REPORT

Threat Analysis | Real-World Examples | Prevention Guidelines

EXECUTIVE SUMMARY

This report provides a comprehensive analysis of phishing threats encountered in real-world scenarios, drawing on actual email samples, header forensics, and authentication record analysis. It is intended for security teams, IT administrators, and end users seeking to strengthen their defenses against social engineering attacks.

3.4 Billion Phishing emails sent daily	90%+ Of breaches start with phishing	\$4.91M Average breach cost (IBM 2023)
--	--	--

Name: Pritee Kailash Rajbhar
CIN: FIT/MAY26/CS8148
Report Date: May 2026
Classification: Internal / Security Awareness
Scope: Email Phishing, Header Analysis, Authentication Records, Prevention

1. Introduction to Phishing Threats

Phishing is one of the most prevalent and dangerous forms of cyberattack in the modern threat landscape. Attackers impersonate trusted entities through email, SMS, or web pages to deceive victims into revealing credentials, transferring funds, or downloading malware. This report documents real-world phishing artifacts to help security professionals and users identify and mitigate these threats.

1.1 Why Phishing Remains So Effective

Phishing succeeds not by exploiting technical vulnerabilities, but by exploiting human psychology. Attackers leverage several cognitive biases and emotional triggers:

- Authority: Emails impersonating banks, government agencies, or IT departments
- Urgency: "Your account will be suspended in 24 hours" pressures hasty decisions
- Fear: Warnings of security breaches or unauthorized access trigger panic responses
- Legitimacy: Modern phishing emails are highly polished, passing visual and even technical checks
- Trust abuse: Using compromised legitimate services (like Zendesk) to send malicious emails

1.2 Threat Categories Covered in This Report

Attack Type	Description
Email Phishing	Deceptive emails using social engineering to steal credentials or redirect victims
Header Spoofing	Manipulating email headers to disguise true sender origin
Service Abuse	Using legitimate platforms (Zendesk, Mailchimp) to deliver phishing content and pass authentication
Malicious Redirects	Obfuscated URLs that route through tracking or redirect services before landing on phishing pages
Authentication Bypass	Emails that pass SPF/DMARC checks while containing fraudulent content

2. Case Study 1 — Wallet Verification Phishing Email

2.1 Overview

This case study examines a phishing email targeting users of a financial or cryptocurrency wallet service. The email was collected from the phishing_pot repository and presents a compelling social engineering scenario disguised as a routine account security notification.

2.2 Email Content Analysis

PHISHING EMAIL — Reconstructed Content

Subject: Verify Your Wallet Now to Ensure Safe and Smooth Access Dear Valued Patron, We extend our heartfelt gratitude for your consistent loyalty and confidence in our offerings. We wish to bring to your attention that the verification process for your wallet is presently awaiting completion. In order to ensure continuous access and a frictionless encounter, we cordially implore your support in concluding the verification procedure via the provided link. [Proceed to Wallet Verification] — <http://trans.mailnr.com/DRAYLF?id=...> Warm regards,

2.3 Technical Indicators of Compromise

2.3.1 Suspicious Redirect URL

The call-to-action link routes through a third-party redirect service rather than pointing directly to any legitimate wallet service domain. This is a classic obfuscation technique:

- Domain used: trans.mailnr.com — not associated with any legitimate financial institution
- The URL contains a long encoded parameter string designed to track clicks and redirect victims
- The rel="noreferrer" attribute was added to prevent browsers from revealing the referrer origin — a common phishing tactic to reduce forensic traceability

2.3.2 HTML Source Code Red Flags (from .EML File)

Analysis of the raw .eml file revealed several technical red flags embedded in the HTML body:

Indicator	Finding
Encoded content	HTML uses Quoted-Printable encoding (=3D, =20, etc.) to obscure content from email scanners
External image hosting	Logo loaded from Amazon S3 (s3.ap-south-1.amazonaws.com) — not the claimed organization's own servers
Hidden tracking span	A with aria-hidden="true" and white text color concealing tracking code [9K=662E-WK01L]
Generic salutation	"Dear Valued Patron" — legitimate services use recipient's actual name
Overly formal language	Unusually elaborate phrasing ("frictionless encounter", "cordially implore") is characteristic of AI-generated or non-native phishing content

2.4 Risk Assessment

Risk Factor	Severity
Credential harvesting via fake wallet login	CRITICAL
Financial asset theft if wallet credentials compromised	CRITICAL
Personal data exposure	HIGH
Device compromise if link leads to malware	HIGH

3. Case Study 2 — Zendesk-Abused Phishing Campaign

3.1 Overview

This case study demonstrates a sophisticated phishing technique in which the attacker abused a legitimate third-party customer support platform (Zendesk) to deliver malicious email. By routing mail through Zendesk's infrastructure, the attacker ensured the email passed standard authentication checks — making it far more dangerous than typical phishing.

3.2 Email Header Analysis

The raw email headers (from the phishing_pot sample) reveal the full delivery chain:

Header Field	Value / Analysis
From:	Customer Care 2 <support@pcpilrjf.zendesk.com> — Random subdomain on Zendesk, not a real brand
Sent:	Sun, 6 Aug 2023 15:47:19 +0000 (UTC)
Delivery To:	<phishing@pot> — A phishing research honeypot address
Originating IP:	188.172.137.15 — Zendesk mail server (outbyoip15.pod17.euw1.zdsys.com)
SPF Result:	PASS — The IP 188.172.137.15 is a legitimate Zendesk sender, so SPF passes
DKIM Result:	PASS (signature verified, header.d=zendesk.com) — Signed by Zendesk, not the attacker
DMARC Result:	PASS — Both SPF and DKIM aligned to zendesk.com; policy action=none
Received Delay:	3 seconds — Normal, no delay-based evasion detected

3.3 Why This Attack Is Particularly Dangerous

WARNING: Authentication Bypass via Legitimate Platform

This email passed DMARC, DKIM, and SPF checks — three of the primary defenses used by email security gateways. A typical automated filter would classify this email as SAFE. This demonstrates that technical authentication alone is insufficient to detect sophisticated phishing attacks.

The attack exploits a fundamental trust gap:

- Zendesk allows anyone to create a subdomain (pcpilrjf.zendesk.com) at low or no cost
- All email from *.zendesk.com is signed with Zendesk's legitimate DKIM key
- SPF records authorize Zendesk's sending infrastructure for zendesk.com subdomains
- Most corporate email gateways whitelist or apply reduced scrutiny to email from known providers like Zendesk
- Recipients are conditioned to trust "support" emails from known platform domains

3.4 MxToolbox Header Analysis Results

The email header was submitted to MxToolbox for forensic analysis. The results confirmed the authentication paradox:

Check	Result	Security Implication
DMARC Compliant	PASS	Passes gateway filters — dangerous
SPF Alignment	PASS	Sender IP is authorized
SPF Authenticated	PASS	Legitimate Zendesk infrastructure
DKIM Alignment	PASS	Aligns with sending domain
DKIM Authenticated	FAIL	Signature verification failed — content may have been modified in transit

KEY FINDING

DKIM Authentication failed despite DKIM Alignment passing. This discrepancy indicates the message may have been altered after signing, OR that the copy/paste process during analysis introduced encoding artifacts. This highlights the limitation of relying solely on automated header checks.

4. Email Authentication Records Deep-Dive

4.1 SPF (Sender Policy Framework)

SPF allows a domain owner to specify which mail servers are authorized to send email on their behalf. It works by publishing a DNS TXT record listing authorized IP addresses and includes.

4.1.1 Example SPF Record Analyzed

```
v=spf1 ip4:52.55.244.91 ip4:18.205.72.90 include:_spf.google.com include:mailgun.org -all
```

Breakdown of this record:

- v=spf1 — SPF version 1 declaration
- ip4:52.55.244.91 and ip4:18.205.72.90 — Two explicitly authorized AWS IP addresses
- include:_spf.google.com — Authorizes all Google GSuite mail servers
- include:mailgun.org — Authorizes the Mailgun transactional email service
- -all — Hard fail: any server NOT in this list is explicitly unauthorized

SPF SECURITY NOTE

This SPF record is well-configured with a hard fail (-all). However, SPF alone does not prevent domain spoofing in the visible From: header — it only validates the envelope sender (MAIL FROM). This is why DMARC is necessary for complete protection.

4.2 DKIM (DomainKeys Identified Mail)

DKIM adds a cryptographic signature to outgoing email, allowing receiving servers to verify that the message was sent and authorized by the domain owner and was not altered in transit.

4.2.1 DKIM Setup Analysis (MxToolbox Delivery Center)

Analysis of the domain's DKIM configuration revealed the following verified sending sources:

Status	Email Source	DKIM Selector	Pass Rate
OK	Mailgun	mailo	100% — Fully configured
OK	Google GSuite	20161025	97% — Well configured
FAILING	Other Sources	None Confirmed	0% (No Volume) — Unverified senders

The "Other Sources" row failing with no confirmed DKIM selectors represents a significant risk — any email sent from an unverified source on behalf of this domain will fail DKIM authentication, but without a strict DMARC policy, these may still be delivered.

4.3 DMARC (Domain-based Message Authentication, Reporting & Conformance)

DMARC ties SPF and DKIM together by specifying what should happen to emails that fail authentication checks. It also provides visibility through aggregate and forensic reporting.

DMARC Policy	Behavior	Recommendation
p=none	Monitor only — failing emails still delivered	Use only during initial deployment/testing
p=quarantine	Failing emails sent to spam folder	Good interim policy during ramp-up
p=reject	Failing emails rejected outright	Target policy for all domains

DMARC FINDING

The analyzed phishing email was sent through Zendesk with action=none — meaning the receiving domain's DMARC policy was set to monitor-only. Even if the email had failed DMARC checks, it would still have been delivered to the recipient's inbox. Organizations must progress to p=reject to block fraudulent emails.

5. Network-Level Analysis & Reconnaissance Context

5.1 Browser DevTools as a Security Investigation Tool

Browser Developer Tools (DevTools), particularly the Network tab, provide valuable insights during security investigations. The screenshot evidence in this report shows DevTools being used to analyze HTTP requests while researching vulnerability assessment resources — a standard practice for security professionals.

Key observations from the network capture:

- HTTP 200 OK responses from cdn infrastructure (gstatic.com) — normal CDN behavior
- Response headers include Cache-Control: public, immutable, max-age=31536000 — aggressive caching for static assets
- Content-Security-Policy-Report-Only header present — indicates the site is actively monitoring for policy violations without enforcing them yet
- Cross-Origin-Opener-Policy: same-origin — protection against cross-origin attacks like Spectre exploits
- Cross-Origin-Resource-Policy: cross-origin — allows resources to be shared across origins (appropriate for CDN assets)

5.2 Suspicious URL Patterns in Phishing Emails

Phishing emails routinely use obfuscated or misleading URLs to evade detection. Common patterns include:

URL Pattern	Why It's Suspicious
trans.mailnr.com/DRAYLF	Redirect service masking the final destination; "mailnr" is not a recognized legitimate domain
Long encoded query strings	Base64 or URL-encoded parameters obscure the payload from URL-scanning security tools
Subdomain of legitimate service	e.g., pcpilrjf.zendesk.com — exploits trust in the parent domain (zendesk.com)
HTTP (not HTTPS)	Lack of TLS certificate indicates an improvised phishing site (though many now use HTTPS)
IP addresses instead of domains	Direct IP links bypass domain reputation checks

6. Phishing Risk Framework

6.1 Attack Vector Risk Matrix

Attack Vector	Likelihood	Impact	Overall Risk
Credential Phishing via Email	Very High	Critical	CRITICAL

Legitimate Service Abuse	High	Critical	CRITICAL
Spear Phishing (Targeted)	Medium	Critical	HIGH
Malicious Attachment	High	High	HIGH
Clone Phishing	Medium	High	HIGH
Vishing / Smishing	Medium	Medium	MEDIUM

7. Prevention Guidelines

7.1 For End Users

7.1.1 Before Clicking Any Link

1. Hover over links before clicking to reveal the actual destination URL in the browser status bar
2. Verify the domain carefully — look for typosquatting (e.g., paypa1.com instead of paypal.com)
3. Be skeptical of any email creating urgency, fear, or pressure to act immediately
4. When in doubt, navigate directly to the service's official website rather than clicking email links
5. Never enter credentials on a page you reached via an email link — go directly to the site instead

7.1.2 Identifying Suspicious Emails

- Generic greetings ("Dear Valued Customer", "Dear User") instead of your actual name
- Sender email address that doesn't match the claimed organization's domain
- Requests for sensitive information (passwords, OTPs, credit card numbers) via email
- Unexpected password reset requests or account verification notices you didn't initiate
- Poor grammar, unusual phrasing, or overly formal language inconsistent with normal communications
- Mismatched logos, unusual formatting, or inconsistent branding

7.2 For IT & Security Teams

7.2.1 Email Authentication Hardening

6. Deploy SPF: Publish SPF records with -all (hard fail) for all organizational domains including unused domains (use v=spf1 -all)
7. Implement DKIM: Configure DKIM signing on all mail-sending services; rotate keys annually and use 2048-bit keys minimum
8. Enforce DMARC: Progress to p=reject policy. Start with p=none for monitoring, move to p=quarantine, then p=reject

9. Monitor DMARC Reports: Review aggregate (rua) and forensic (ruf) reports to identify unauthorized senders and misconfigured sources
10. Configure BIMI: Implement Brand Indicators for Message Identification to display verified logos in supported email clients

7.2.2 Technical Controls

- Deploy email security gateways with URL rewriting and real-time URL scanning
- Implement sandboxing for email attachments before delivery
- Enable Advanced Anti-Phishing policies in your email platform (Microsoft Defender, Google Workspace)
- Block or restrict free subdomain services (*.zendesk.com, *.mailchimp.com) at the gateway level where operationally feasible
- Implement DNS-based filtering (e.g., Cisco Umbrella, Cloudflare Gateway) to block known phishing domains
- Deploy Multi-Factor Authentication (MFA) on all accounts — credential theft becomes far less valuable
- Use hardware security keys (FIDO2/WebAuthn) for privileged accounts as phishing-resistant MFA

7.2.3 Monitoring & Detection

- Monitor for lookalike domain registrations using services like DomainTools or automated DMARC reporting
- Implement SIEM rules to alert on authentication anomalies (logins from new locations/devices after phishing-indicative events)
- Set up honeypot email addresses to detect phishing campaigns targeting your organization
- Conduct regular phishing simulation exercises to measure and improve employee resilience

7.3 Incident Response Procedures

When a phishing email is reported or suspected:

#	Phase	Actions
1	Contain	Quarantine the suspicious email; revoke any clicked links at gateway level; reset credentials if entered on phishing page
2	Investigate	Analyze email headers; extract and examine all URLs; submit to threat intelligence platforms (VirusTotal, PhishTank); identify all recipients
3	Remediate	Remove email from all mailboxes; block malicious domains/IPs; force password resets for affected accounts; revoke active sessions
4	Communicate	Notify affected users; issue security advisory to all staff if campaign is widespread; escalate to management if sensitive data was accessed
5	Document & Learn	Document the attack vector, timeline, and impact; update detection rules; schedule awareness training refresh based on lessons learned

8. Recommended Tools & Resources

Tool / Resource	Purpose	URL / Notes
MxToolbox Email Analyzer	Analyze email headers, SPF, DKIM, DMARC	mxtoolbox.com/EmailHeaders.aspx
VirusTotal	Scan URLs and files for malicious content	virustotal.com
PhishTank	Verify if a URL is a known phishing site	phishtank.com
DMARC Analyzer	Monitor and analyze DMARC reports	dmarcanalyzer.com
Google Safe Browsing	Check URL safety in real-time	transparencyreport.google.com/safe-browsing
ANY.RUN	Interactive malware sandboxing	any.run — for analyzing suspicious attachments
Have I Been Pwned	Check if credentials were exposed in breaches	haveibeenpwned.com
OWASP Phishing Guide	Comprehensive phishing defense documentation	owasp.org/www-project-phishing-prevention

9. Conclusion

The phishing attacks analyzed in this report illustrate the evolving sophistication of modern social engineering campaigns. Two key takeaways emerge from this analysis:

- Technical authentication controls (SPF, DKIM, DMARC) are necessary but insufficient. The Zendesk-based campaign demonstrates that attackers are actively exploiting legitimate infrastructure to bypass these controls. The solution is layered defense: combine technical controls with behavioral analytics, user training, and strict DMARC policies.
- Human factors remain the primary attack surface. The wallet phishing email succeeded not because of technical sophistication but because of psychological manipulation — creating urgency and impersonating authority. No technical control fully eliminates this risk; continuous security awareness training is essential.

RECOMMENDED IMMEDIATE ACTIONS

1. Review and harden your DMARC policy — progress toward p=reject
2. Audit all authorized sending sources and ensure DKIM is configured for each
3. Deploy phishing-resistant MFA (FIDO2/hardware keys) on all privileged and email accounts
4. Conduct a phishing simulation within the next 30 days to establish baseline user susceptibility
5. Establish an incident response runbook for phishing reports

Phishing defense is not a one-time project but a continuous program. The threat landscape evolves rapidly — regular review of authentication records, ongoing employee training, and proactive threat hunting are essential components of a resilient security posture.

Appendix A — Glossary

Term	Definition
DKIM	DomainKeys Identified Mail — a cryptographic email signing standard that allows receivers to verify the sender's authenticity and message integrity
DMARC	Domain-based Message Authentication, Reporting & Conformance — a policy framework that builds on SPF and DKIM to specify how failing emails should be handled
SPF	Sender Policy Framework — a DNS-based mechanism that specifies which mail servers are authorized to send email for a domain
EML	Electronic Mail format — a file format for storing individual email messages, including all headers and body content
QP Encoding	Quoted-Printable encoding — a MIME encoding scheme that encodes non-ASCII characters using = followed by hex values (e.g., =3D for '=')
Honeypot	A security resource designed to attract and detect attackers; phishing honeypots are email addresses published to catch spam and phishing campaigns
BIMI	Brand Indicators for Message Identification — a standard that allows verified senders to display their brand logo in email clients
Spear Phishing	Highly targeted phishing attack directed at specific individuals or organizations, using personalized information to increase credibility
Typosquatting	Registering domain names similar to legitimate ones (e.g., g00gle.com) to catch users who mistype URLs or fail to notice subtle differences
FIDO2	Fast Identity Online 2 — a phishing-resistant authentication standard using hardware keys or biometrics instead of passwords